UNIT 4 · TOPIC 4.4

Endpoint Threat Auditing

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A security analyst wants to monitor activities on a single workstation for signs of attack originating on or targeting that machine. Which type of tool is specifically designed to detect attacks by monitoring events on the host device itself?

- ○ A. Network-based Intrusion Detection System (NIDS)
- ○ B. Web Application Firewall (WAF)
- **● C. Host-based Intrusion Detection System (HIDS)**
- ○ D. Packet analyzer

Correct answer: C

Why: A HIDS monitors events on the host device, file changes, process activity, login events, to detect attacks occurring on or against that specific machine. A NIDS monitors network traffic passing through a segment; a WAF filters web-layer HTTP requests; a packet analyzer captures and decodes raw network frames. None of those three operate at the individual host level for general endpoint event detection.

*Why the others are wrong: **A**, NIDS operates at the network level and inspects traffic flowing between devices; it cannot observe local file-system events or process behavior on a single host. **B**, A WAF sits in front of web servers and filters HTTP/HTTPS requests, it is not a general-purpose host monitoring tool. **D**, Packet analyzers (e.g., Wireshark) capture and decode network frames; they do not monitor host-local events such as login attempts or process launches.*

2. In the context of device security, which term describes observable evidence found on or produced by a host that suggests a security incident may have occurred or be in progress?

- ○ A. Vulnerability
- ○ B. Threat vector
- ○ C. Attack surface
- **● D. Indicator of Compromise (IoC)**

Correct answer: D

Why: An Indicator of Compromise (IoC) is observable evidence, such as unusual log entries, unexpected processes, unfamiliar file hashes, or anomalous network connections, that indicates a device may have been compromised or is under active attack. Vulnerabilities are weaknesses that could be exploited; threat vectors are the pathways through which an attack reaches a system; attack surface is the aggregate of all exploitable entry points on a system.

*Why the others are wrong: **A**, A vulnerability is a weakness in a system that could be exploited; it is a precondition for attack, not evidence that an attack has occurred. **B**, A threat vector describes how an attacker reaches a target (e.g., phishing email, unpatched service), not evidence left behind by an attack. **C**, Attack surface refers to the sum of all points where an unauthorized user could interact with a system, a design concept, not post-incident evidence.*

3. An administrator reviews an authentication log and finds 350 failed login attempts targeting the "admin" account from the same IP address, all occurring within a two-minute window. Which attack does this pattern most clearly indicate?

- ○ A. SQL injection
- **● B. Brute-force password attack**
- ○ C. Cross-site scripting (XSS)
- ○ D. Man-in-the-middle (MITM) attack

Correct answer: B

Why: A high volume of failed login attempts against a single account from a single source in rapid succession is the textbook signature of a brute-force attack, where an attacker systematically submits password guesses. SQL injection exploits database query inputs; XSS injects malicious scripts into web pages; MITM attacks intercept traffic between two parties. None of those three produce repeated authentication failures in a log.

*Why the others are wrong: **A**, SQL injection targets database query parsing, it does not manifest as repeated authentication failures in a login log. **C**, XSS injects client-side scripts through web input fields; it has no relationship to repeated authentication failure events. **D**, MITM attacks intercept or relay communications between parties; they do not generate large volumes of failed login attempts originating from the attacker's IP.*

4. Dynamic's security team wants to ensure that any unauthorized modification to executable files on its manufacturing-network workstations is detected as quickly as possible. Which detection control is most appropriate for this specific requirement?

○ A. Deploy a network-based IDS to monitor all ingress traffic at the manufacturing network boundary

● **B. Enable file integrity monitoring (FIM) on the workstations**

○ C. Configure a web application firewall on the manufacturing subnet gateway

○ D. Install a mail gateway to filter phishing attachments before delivery

Correct answer: B

Why: File Integrity Monitoring (FIM) continuously records cryptographic hashes of specified files, particularly executables and system files, and raises an alert when any hash changes unexpectedly. This directly addresses unauthorized modification of files on the host. A boundary NIDS sees network traffic but cannot inspect the file system of individual endpoints; a WAF filters web-layer requests, not host-level file operations; a mail gateway prevents phishing delivery but cannot detect on-host tampering.

*Why the others are wrong: **A**, A boundary NIDS captures network packets crossing the perimeter; it has no visibility into file-system state changes occurring on individual workstations. **C**, A WAF operates at the HTTP/HTTPS application layer in front of web servers; it does not monitor file integrity on endpoints. **D**, A mail gateway intercepts malicious email attachments before they reach users, it addresses delivery of malware, not subsequent unauthorized changes to already-installed executables.*

5. A security team wants to both detect and limit the damage from brute-force password attacks against manufacturing workstation accounts. Which combination of controls best addresses both goals simultaneously?

○ A. Firewall rules and antivirus scanning

○ B. Patch management and vulnerability scanning

○ C. Full-disk encryption and VPN access control

● **D. Account lockout policies and authentication log monitoring**

Correct answer: D

Why: Account lockout policies limit damage by automatically locking accounts after a defined number of failed attempts, stopping ongoing brute-force in progress. Authentication log monitoring provides detection by alerting analysts to abnormal login patterns before or after lockout occurs. Together they form a complementary detect-and-limit pair. The other combinations address different threat categories: firewalls and AV address network filtering and malware; encryption and VPN address confidentiality and remote access; patching and vulnerability scanning address known exploitable weaknesses.

*Why the others are wrong: **A**, Firewalls filter network traffic by rule and AV scans for malware signatures, neither directly detects or limits credential brute-force at the authentication layer. **B**, Patching closes known software vulnerabilities and vulnerability scanning identifies them, these are proactive controls that do not detect or limit active credential attacks. **C**, Disk encryption protects data at rest from physical theft; VPN secures remote access tunnels. Neither addresses the authentication failure pattern of a brute-force attack.*

6. Dynamic's security team needs to correlate authentication log events from 40 manufacturing workstations to identify coordinated attack patterns across the environment. Which detection strategy is most scalable and effective for this requirement?

○ A. Manually review each workstation's local log file on a daily schedule

○ B. Install a standalone HIDS on each workstation with no central aggregation or correlation

● C. Deploy a Security Information and Event Management (SIEM) system to centralize log collection and apply correlation rules

○ D. Rely on each endpoint's antivirus alert notifications independently

Correct answer: C

Why: A SIEM ingests log data from all endpoints into a central repository, applies correlation rules across the full dataset, and can detect patterns that span multiple devices, such as a coordinated password spray targeting different accounts on different workstations from rotating source IPs. Manual review and per-host standalone tools fundamentally cannot detect cross-device attack patterns because they operate in isolation. Antivirus alert streams are signature-based and do not correlate authentication events.

*Why the others are wrong: **A**, Manual daily review of 40 individual hosts does not scale, introduces significant latency in detection, and cannot cross-correlate events occurring simultaneously across machines. **B**, Standalone HIDS tools on each host can detect local anomalies but cannot identify multi-host patterns without a central aggregation and correlation layer. **D**, Antivirus alerts are triggered by file/process signatures; they do not ingest or correlate authentication log events and are not designed for credential attack detection across an environment.*

7. Dynamic's security architect proposes two detection strategies for the manufacturing network: (A) deploy HIDS agents on every workstation, or (B) deploy a single NIDS at the perimeter where the manufacturing network connects to the business network. The threat scenario is an attacker who has already gained a foothold in the business network and may attempt lateral movement into manufacturing. Which statement most accurately evaluates the limitations of the perimeter-only NIDS strategy for this scenario?

○ A. A perimeter NIDS is superior because it requires fewer licensing costs than HIDS agents on every endpoint.

○ B. A perimeter NIDS will generate fewer false positives than HIDS because it only sees traffic crossing the boundary, making it strictly preferable.

● C. A perimeter NIDS cannot detect attacks originating from within the manufacturing network or carried over encrypted channels, leaving critical blind spots in this specific threat scenario.

○ D. A perimeter NIDS is sufficient because all attacks from the business network must traverse the boundary sensor before reaching manufacturing endpoints.

Correct answer: C

Why: A perimeter NIDS only inspects traffic crossing the boundary between networks. It has two critical blind spots relevant to this scenario: (1) lateral movement traffic between devices already inside the manufacturing network is invisible to it, and (2) encrypted C2 channels (e.g., TLS-encapsulated traffic) cannot be inspected without additional decryption infrastructure. Given that the attacker may already be inside or may pivot through encrypted channels, a perimeter-only NIDS would miss key attack phases. HIDS agents on individual endpoints detect local file changes, process anomalies, and authentication events regardless of network position or encryption state.

*Why the others are wrong: **A**, Licensing cost is not a security evaluation criterion; the question asks to evaluate detection capability, not total cost of ownership. **B**, Lower false positives at the perimeter do not compensate for the detection gap created by lateral movement and encrypted traffic blind spots, reducing false positives while missing real attacks worsens overall detection effectiveness. **D**, An attacker operating inside the manufacturing network (e.g., after pivoting from a compromised business-network host already authorized to communicate with manufacturing) may not generate traffic that crosses the boundary sensor at all.*

8. Dynamic's security team is choosing between a signature-based endpoint detection tool and a behavioral anomaly detection tool for its manufacturing workstations. A colleague argues that since the threat involves a persistent adversary from a prior breach, behavioral detection is strictly preferable and signatures can be dropped entirely. Which evaluation of this argument is most accurate?

○ A. The argument is correct; behavioral tools fully replace signature-based detection in all environments.

○ B. The argument is incorrect only because behavioral detection tools are too computationally expensive to run on industrial workstations.

● C. The argument overstates the case: while behavioral detection is better suited to novel or persistent threats, signature tools efficiently catch known malware families with near-zero false positives, a defense-in-depth approach using both is more effective than either alone.

○ D. The argument is correct for detecting novel attacks, but behavioral tools cannot classify any known attack types.

Correct answer: C

Why: Behavioral detection excels at identifying anomalous activity patterns, including novel or zero-day threats and living-off-the-land techniques that leave no file signature, and is particularly valuable for detecting a persistent adversary using customized tooling. However, signature-based detection efficiently identifies known malware families with very high confidence and minimal analyst overhead. Dropping signatures entirely means losing that high-fidelity, low-effort coverage for the large volume of commodity malware. Defense-in-depth dictates using complementary controls whose strengths offset each other's weaknesses, not replacing one with the other. Computational cost is a real operational consideration for ICS/manufacturing environments but is not the core flaw in the argument.

*Why the others are wrong: **A**, No current behavioral tool provides complete coverage for all attack types; signature tools remain highly effective for known malware and carry lower analyst overhead for those specific cases. **B**, Computational overhead is a real operational factor in ICS environments but is not the primary flaw in the argument, the argument's core error is the claim that behavioral detection makes signatures entirely redundant. **D**, This inverts the actual limitation: behavioral and anomaly-based tools frequently detect novel threats that signatures miss, but they can struggle with accurate classification of specific known attack subtypes, whereas signatures excel at that classification task.*

9. During post-incident review, Dynamic's forensic team discovers that authentication logs needed to reconstruct the full attack timeline were overwritten: the default retention period was 24 hours, and the attack occurred 9 days before the investigation. The security team had real-time alerting in place during the attack window but no analyst acted on the alerts. Which evaluation of this outcome is most accurate?

○ A. The detection strategy was adequate; real-time alerting fulfills the detection requirement and log retention is only an administrative concern.

○ B. The failure was purely a staffing issue; the detection strategy itself was sound, and additional security personnel would have resolved both problems.

● C. The detection strategy was doubly flawed: the alert-fatigue problem indicates the alerting configuration lacked sufficient tuning or prioritization, and the absence of adequate log retention eliminated forensic reconstruction capability, effective detection strategy must address both real-time response and evidence preservation.

○ D. Log retention is irrelevant if real-time alerting is functional, since all necessary information is captured at alert generation time.

Correct answer: C

Why: This scenario reveals two distinct failures in the detection strategy. First, the real-time alerting system generated alerts that went unacted upon, a classic alert-fatigue symptom that indicates alerting volume, prioritization, or escalation procedures were not properly configured. Second, the 24-hour default log retention left no forensic record of the event for post-incident analysis, meaning the team cannot determine what the attacker accessed, what persistence mechanisms were set, or what the full scope of the breach was. A complete detection strategy must account for both the operational response dimension (actionable, well-prioritized alerts) and the forensic preservation dimension (sufficient retention to support retrospective investigation).

*Why the others are wrong: **A**, Log retention is a direct component of a detection strategy's effectiveness, without it, the team loses the ability to investigate incidents detected outside the real-time window and cannot reconstruct attacker actions post-authentication. **B**, Staffing is a contributing factor, but the detection strategy itself was structurally flawed: alerts that go unacted upon by all available staff indicate a configuration or escalation design failure, not simply a headcount problem. **D**, Real-time alert records capture that an event occurred but rarely capture the full detail of log entries needed for forensic timeline reconstruction, scope determination, and attribution, authentication log files contain far more contextual data than a single alert notification.*

10. Which type of password attack is characterized by systematically trying every possible character combination, including letters, numbers, and symbols, until the correct password is found?

○ A. Dictionary attack

○ B. Rainbow table attack

● **C. Brute-force attack**

○ D. Credential stuffing

Correct answer: C

Why: A brute-force attack exhaustively tries every possible combination of characters from a defined character space. A dictionary attack uses a pre-built wordlist of commonly used or likely passwords rather than exhaustive enumeration; a rainbow table attack uses precomputed hash chains to reverse stored password hashes offline rather than submitting guesses to a live system; credential stuffing reuses username/password pairs leaked from prior breaches on other services.

*Why the others are wrong: **A**, A dictionary attack draws from a finite list of candidate passwords, it is faster and more targeted than brute-force but will miss passwords not on the list. **B**, Rainbow table attacks are an offline cryptanalysis technique against stored password hashes; they do not generate login attempts against a live authentication system. **D**, Credential stuffing relies on lists of already-known valid credentials from prior breaches, not on generating new candidate passwords through enumeration.*

11. A HIDS generates an alert because an unknown process on a manufacturing workstation is making repeated outbound connection attempts to an external IP address on an unusual port. This behavior is most consistent with which type of attack?

○ A. Denial-of-service (DoS) attack against an external target

● **B. Command-and-control (C2) communication by malware installed on the device**

○ C. SQL injection against a web application

○ D. Physical hardware tampering

Correct answer: B

Why: Repeated outbound connection attempts from an unknown process to an external IP, especially on an unusual port, are a hallmark of malware attempting to establish a C2 channel, "calling home" to receive instructions or exfiltrate data. DoS attacks flood a victim with traffic but do not generate unknown-process outbound connection patterns logged by a HIDS; SQL injection targets database query parsing in web applications; physical tampering is a hardware-level action and does not produce process-based network events.

*Why the others are wrong: **A**, DoS attacks send large volumes of traffic toward a victim, the attacking device would generate high-volume outbound traffic, not the low-frequency repeated connection pattern characteristic of a C2 beacon. **C**, SQL injection exploits parameterized database queries within a web application stack; it does not manifest as an unknown system process making outbound network connections. **D**, Physical tampering occurs at the hardware layer, by definition it does not generate software process events or network connection logs on the host.*

12. In an authentication log, which entry pattern most clearly indicates a successful unauthorized access following a brute-force attack?

○ A. A single failed login followed by no further activity from that IP address

● **B. Hundreds of failed login attempts from one IP address, immediately followed by a successful login from that same IP**

○ C. Multiple successful logins from a user's usual device at the usual time of day

○ D. One failed login followed immediately by a password reset request originated by the user

Correct answer: B

Why: The pattern of a large volume of failed attempts from a single source immediately followed by a successful login from that same source is a strong indicator that an attacker exhausted many guesses and eventually found the correct credential. A single failure with no follow-up suggests an accidental mistype; repeated successes from a familiar device at expected times represent normal user behavior; a failed login followed by a user-initiated reset is a common legitimate response to a forgotten password.

*Why the others are wrong: **A**, A single failed attempt with no subsequent activity is consistent with an accidental password mistype and is not sufficient to indicate an attack. **C**, Multiple successes from a known device at expected times are normal, expected behavior, this is the pattern the security team should be training against as a baseline. **D**, A single failure followed by a user-initiated reset is a routine, legitimate workflow for a user who has forgotten their password and is not an indicator of attack.*

13. You are a forensic analyst at Dynamic, reviewing authentication logs for the manufacturing network after a suspected lateral-movement attempt from the compromised office network. You observe the following events on workstation MFG-07 over a 10-minute window:

02:14:01, FAILED user:"admin" src:10.0.1.45
02:14:03, FAILED user:"administrator" src:10.0.1.45
02:14:05, FAILED user:"root" src:10.0.1.45
[224 additional FAILED entries targeting common username variants, src:10.0.1.45]
02:23:58, SUCCESS user:"mfg_svc" src:10.0.1.45

Which classification and next step are most appropriate?

○ A. Normal scheduled maintenance activity; the service account login at 02:23 is expected. No action required.

○ B. Phishing attack; notify the owner of the "mfg_svc" account to change their password and re-enable the account.

● C. Dictionary attack against common default usernames, successful on account "mfg_svc"; treat the successful login as a critical IoC, lock the account, and investigate post-authentication activity on MFG-07.

○ D. Denial-of-service attack; block 10.0.1.45 at the perimeter firewall and close the incident.

Correct answer: C

Why: The sequential trial of known default and administrative username variants (admin, administrator, root, etc.) from a single source over a compressed window is a dictionary attack targeting default account names, not random brute-force character enumeration. The eventual success on "mfg_svc" is a high-severity IoC: the attacker now has authenticated access to a manufacturing workstation. The correct response is to immediately lock the compromised account, preserve all logs, and investigate what the attacker did post-authentication (what commands ran, what files were accessed, whether persistence was established). Maintenance logins occur from known admin IPs at scheduled times and do not follow 227 failures; phishing produces different evidence (email artifacts, user interaction); DoS attacks do not produce authenticated login successes.

*Why the others are wrong: **A**, Legitimate scheduled maintenance does not begin with 227 failed login attempts across multiple username variants at 02:14 AM, this is not a normal operational pattern for any service account. **B**, Phishing attacks are delivered via email and require a user to interact with a malicious link or attachment; they do not generate repeated authentication failures across many username variants in an authentication log. **D**, DoS attacks target availability, they do not produce a successful authenticated login event. Blocking the IP without preserving the account compromise evidence and investigating post-auth activity would leave an active threat actor with a foothold.*

14. Reviewing authentication logs for Dynamic's manufacturing network, you find the following events targeting workstation MFG-12 over a 45-minute period:

09:01:14, FAILED user:"mfg_ops" src:10.0.1.22 password_tried:"Password1"
09:19:47, FAILED user:"mfg_ops" src:10.0.1.31 password_tried:"Summer2023!"
09:44:02, FAILED user:"mfg_ops" src:10.0.1.19 password_tried:"Welcome1"

Which attack type does this log pattern most likely represent, and why?

○ A. Brute-force attack, because multiple passwords are being tried against the same account

○ B. Keylogger-based credential theft, because the attacker knows which specific passwords to try

○ C. Rainbow table attack, because the passwords attempted are common and precomputed hashes exist for them

● **D. Password spray attack, because a small set of commonly used passwords is being tried slowly from multiple source IPs to stay below account lockout thresholds**

Correct answer: D

Why: Password spraying uses a small, carefully chosen set of commonly used passwords (like seasonal variations, keyboard patterns, or corporate defaults) and tries them slowly against one or more accounts, often rotating source IPs to stay below lockout thresholds. The 15–25 minute gaps between attempts and the use of three different source IPs are deliberate evasion, this is a defining characteristic of a spray attack, not brute-force. Brute-force is high-volume and rapid from a single source. Rainbow table attacks are an offline cryptanalytic technique against stored hashes, they do not appear as live login attempts in authentication logs. A keylogger captures credentials the user types; it does not produce failed login entries because it submits the correct credential directly.

*Why the others are wrong: **A**, A true brute-force attack submits a high volume of attempts in rapid succession from a single source; 3 attempts over 45 minutes from 3 different IPs is inconsistent with brute-force methodology and is clearly paced to evade lockout detection. **B**, A keylogger silently captures the correct credentials and submits them in a single successful login; it does not produce any failed login entries and does not appear in this type of pattern. **C**, Rainbow table attacks are performed offline against a stolen password database, they never generate live authentication log entries on the target system.*

15. When analyzing authentication log files to identify indicators of a password attack against manufacturing workstations, which combination of log fields should a forensic analyst prioritize correlating?

● **A. Source IP address, event timestamp, login success/failure status, and targeted username**

○ B. Username, file hash, and CPU usage at time of event

○ C. Destination TCP port, DNS query name, and network interface MAC address

○ D. Process ID, memory usage at event time, and disk write rate

Correct answer: A

Why: Effective detection of password attacks from authentication logs requires correlating four key fields: source IP (to identify the origin and detect rotating-IP spray patterns), timestamp (to determine attack rate, identify low-and-slow patterns, and establish timeline), login success/failure status (to identify both the ongoing attack and the moment of compromise), and targeted username (to classify the attack type, brute-force against one account vs. spray across many). The other field sets belong to different analysis domains: file hashes and CPU/memory/disk metrics are used in malware behavioral analysis; TCP ports, DNS, and MACs are network forensics fields; none of these are primary authentication log fields for credential attack detection.

*Why the others are wrong: **B**, File hashes and CPU usage are indicators used in malware and endpoint behavioral analysis, not the core fields of an authentication event log entry for credential attack detection. **C**, TCP destination port, DNS query names, and MAC addresses are network-layer indicators from packet captures or DNS logs, they are not the primary fields in authentication event logs for classifying credential attacks. **D**, Process ID, memory usage, and disk write rate are system performance and malware behavioral indicators, useful in incident response for detecting malware post-compromise, but not the correct fields for classifying password attacks from authentication logs.*

16. Dynamic is evaluating an AI-assisted Endpoint Detection and Response (EDR) tool that uses a machine learning classifier trained on historical attack datasets to automatically classify device attacks. A senior engineer argues the tool should replace human analyst review entirely, since AI detection is faster, more consistent, and never fatigued. Which evaluation of this argument is most accurate?

● **A. The argument overstates AI capability: ML classifiers can produce false positives and false negatives, are constrained by their training distribution, and cannot apply organizational context, human analysts remain essential for validation, triage, and response authorization, particularly in a manufacturing environment where incorrect automated action carries operational risk.**

○ B. The argument is correct; modern AI-based EDR tools have achieved sufficient accuracy to eliminate the need for human analysts in all incident classification tasks.

○ C. The argument is incorrect primarily because AI tools are too expensive for manufacturing environments and should be replaced by cheaper rule-based detection.

○ D. The argument is partially correct: AI tools can detect novel attacks perfectly but cannot classify any known attack types, so human analysts should handle only known-attack classification.

Correct answer: A

Why: AI-based EDR tools improve speed and detection breadth, but ML classifiers trained on historical data have well-documented limitations: they can misclassify novel attack variants outside their training distribution, generate false positives in legitimate but unusual operational configurations (like maintenance windows that resemble attack patterns), and have no access to organizational context (e.g., "this unusual admin login at 3 AM is actually a scheduled patch window"). In a manufacturing environment, an incorrect automated response, blocking a critical service account, quarantining a process control workstation, can halt production with significant safety and financial consequences. Human analysts validate findings, apply business context, authorize proportionate responses, and manage edge cases. The correct model is human-AI collaboration, not replacement.

*Why the others are wrong: **B**, No current ML-based EDR system reliably handles all edge cases, novel techniques, and organizational context, false positives and novel attack variants outside the training distribution remain unresolved challenges across the industry. **C**, Cost is not the primary flaw in the argument; the argument's error is the claim that AI accuracy and consistency fully substitute for human judgment, a capability gap, not a cost gap. **D**, This inverts the actual trade-off: behavioral ML tools often detect novel attacks via anomaly scoring (their relative strength), but they can struggle with accurate subtype classification of known attack families, whereas rule-based signature tools excel at known-type classification with high precision.*

17. After completing log analysis for Dynamic's manufacturing network, the forensic analyst reports that authentication logs alone were insufficient to fully classify the scope and impact of the attack, they could confirm that a service account was compromised but could not determine what the attacker did afterward. Which evaluation of the detection method's impact most accurately explains this limitation?

○ A. Authentication logs are not a valid source for incident response; only full network packet captures provide reliable evidence.

○ B. Authentication logs are fully sufficient for attack classification when log timestamps are accurately synchronized across hosts.

○ C. The limitation arose because the logs were stored in plain text format, which made the post-authentication entries unreadable.

● D. Authentication logs accurately record credential-based attack events but have an inherent scope boundary: they do not capture post-authentication behavior, so they cannot alone classify what an attacker did after gaining access, full attack classification requires correlating authentication logs with process, file access, and network flow data.

Correct answer: D

Why: Authentication logs record events at the authentication boundary: who attempted to log in, from where, when, and whether it succeeded. Once a session is established, authentication logging stops, it does not record which files the attacker opened, which commands were executed, which data was exfiltrated, or what persistence mechanisms were installed. Comprehensive attack classification requires correlating authentication records with process execution logs (e.g., Windows Event ID 4688 or Linux auditd records), file access logs, network connection logs, and ideally SIEM correlation across all sources. Authentication logs are necessary but not sufficient for full scope determination after a successful compromise.

*Why the others are wrong: **A**, Authentication logs are a critical, high-value evidence source for detecting and classifying credential-based attacks; dismissing them in favor of packet captures alone would lose the identity-layer context they uniquely provide. **B**, Accurate timestamp synchronization (e.g., via NTP) is essential for log correlation across hosts but addresses ordering accuracy, not the fundamental gap in post-authentication behavioral visibility that authentication logs cannot capture regardless of timestamp precision. **C**, Plain text storage is a security hardening concern (logs should be integrity-protected) but does not explain an analytical scope limitation, the content of plain text logs is fully readable and usable.*

18. Dynamic's security team deployed signature-based antivirus as the sole detection mechanism on all manufacturing endpoints, believing it would provide comprehensive coverage. During a subsequent incident investigation, analysts discovered the attacker used a fileless technique, injecting malicious code into a legitimate

running process using native OS scripting tools, with no malicious file ever written to disk. Which evaluation of the detection strategy's impact is most accurate?

○ A. The strategy was sound; signature-based antivirus is the industry-standard endpoint control and covers all modern attack techniques.

○ B. The strategy was appropriate for a manufacturing environment because fileless attack techniques are rare in operational technology contexts and were unlikely to be encountered.

○ C. The impact was limited because fileless attacks cannot persist across system reboots, so reimaging the workstations would have resolved the compromise without needing detection.

● D. The strategy had a fundamental blind spot: signature-based antivirus scans file artifacts on disk and cannot detect fileless attacks that operate entirely in memory or inject into legitimate processes, detecting this class of attack requires behavioral monitoring or memory-analysis capabilities such as those provided by EDR solutions.

Correct answer: D

Why: Signature-based antivirus operates by scanning files on disk against a database of known malware signatures. Fileless attacks deliberately avoid writing executable artifacts to disk, instead injecting code into memory of legitimate processes (e.g., via PowerShell, WMI, or process hollowing) or using LOLBins (Living-Off-the-Land Binaries), native OS tools already present and trusted on the system. Because there is no file artifact, signature scanning has nothing to match against. Detecting fileless attacks requires behavioral monitoring: watching for anomalous process behaviors (e.g., PowerShell spawning from a process that should never invoke it, unusual process memory access patterns, unexpected WMI subscriptions), which is the domain of EDR and behavioral HIDS tools. Relying solely on signature AV is a well-documented coverage gap in modern threat landscapes, including in industrial environments increasingly targeted by sophisticated actors.

*Why the others are wrong: **A**, Signature-based antivirus is a foundational but not comprehensive control; its inability to detect fileless techniques is a well-established limitation that has driven the development of EDR and behavioral detection platforms across the industry. **B**, Fileless techniques are increasingly common in targeted attacks against industrial and manufacturing environments precisely because security teams in those environments often rely on traditional controls with this blind spot; their rarity cannot be assumed. **C**, Some fileless attacks achieve persistence through registry modifications (e.g., Run keys), scheduled tasks, WMI subscriptions, or COM hijacking, mechanisms that survive reboots, making the assumption that reimaging resolves the compromise without detection dangerously incomplete.*